Rapport de Travaux Pratiques : Gestion des Vulnérabilités avec Nessus

1. Informations Générales

- Ubuntu (Linux) : 192.168.56.10
- Windows : 192.168.56.20

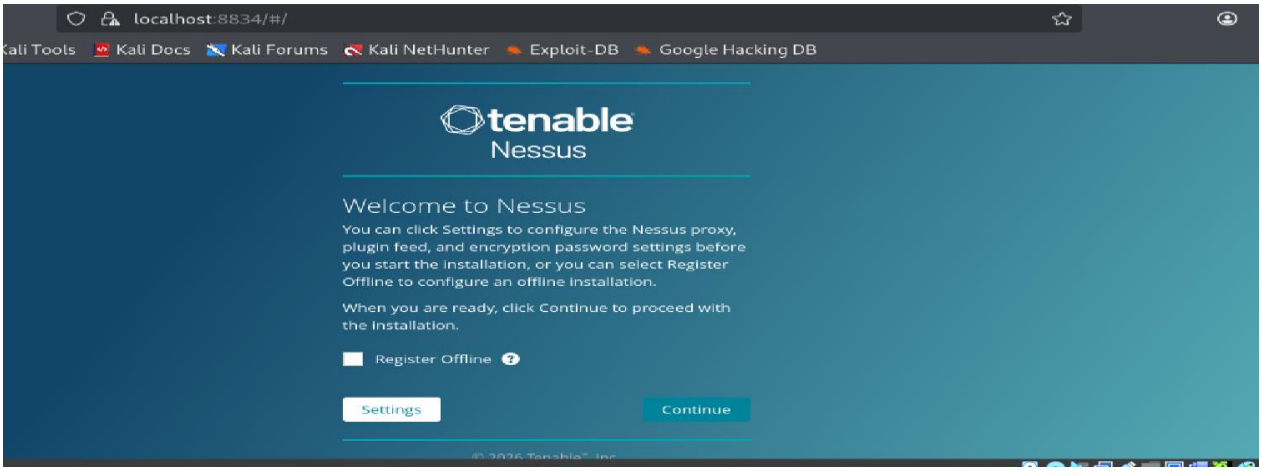
2. Procédure Technique

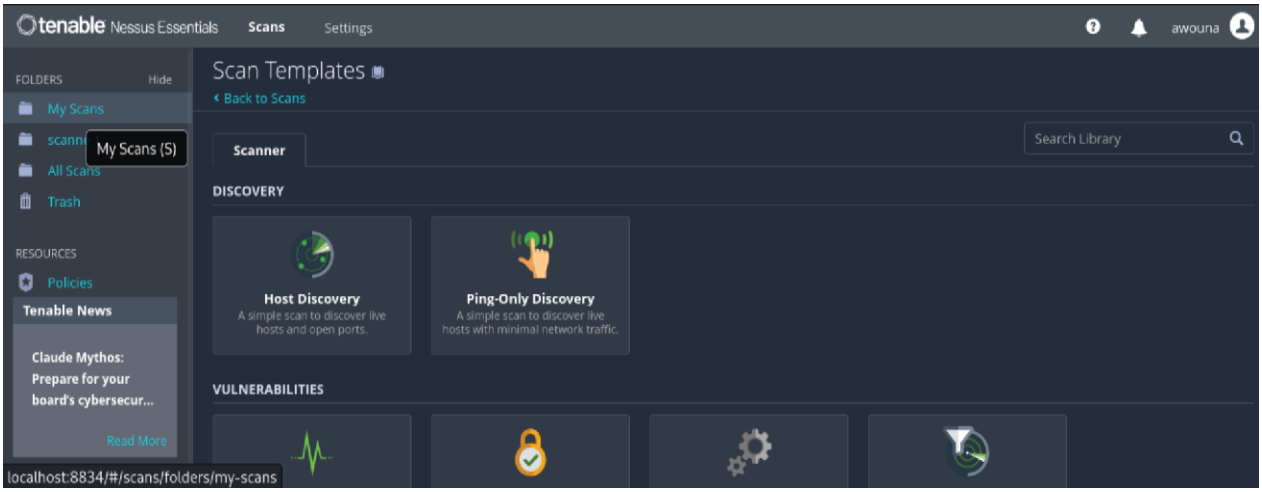
Installation du paquet : sudo dpkg -i Nessus-*.deb

1. **Activation du service :** sudo systemctl start nessusd

```
┌──(awouna㉿awouna)-[~]
└─$ sudo systemctl start nessusd
[sudo] Mot de passe de awouna :
```

2. **Interface de gestion :** Accès via le navigateur à https://localhost:8834

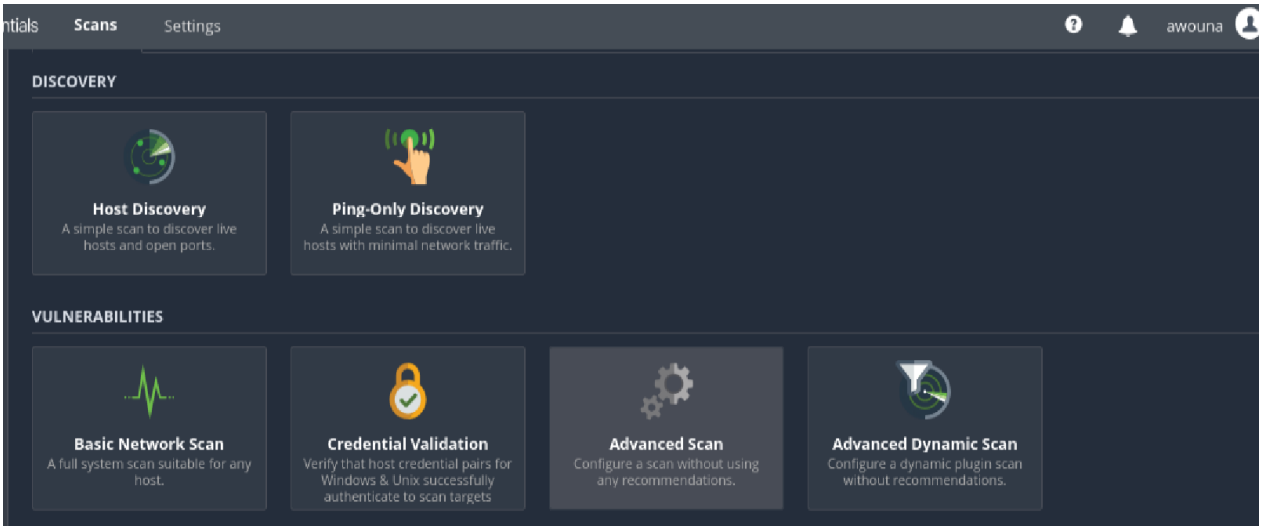




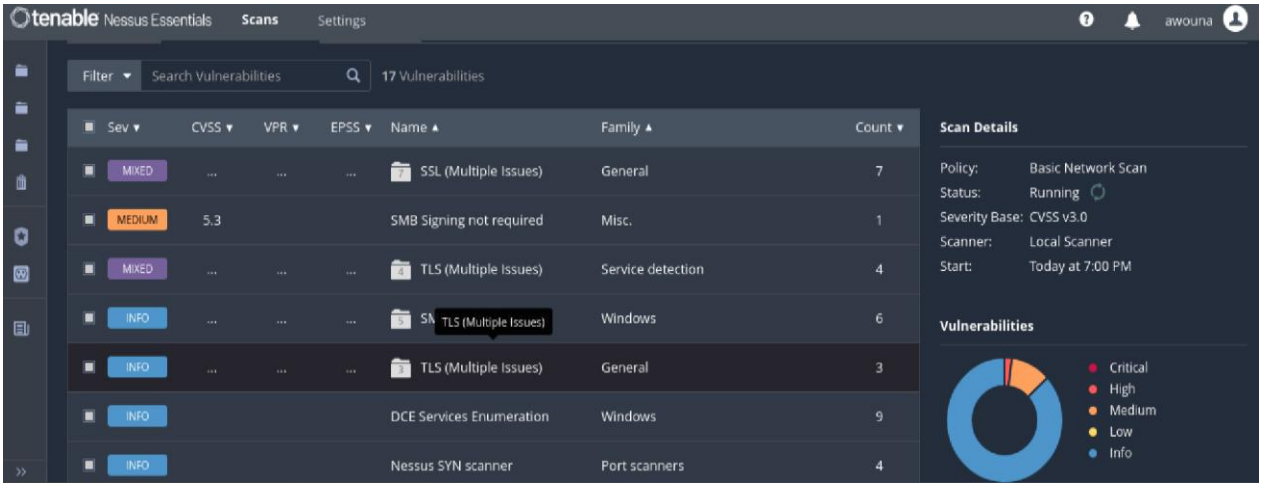
A. Configuration du Scan

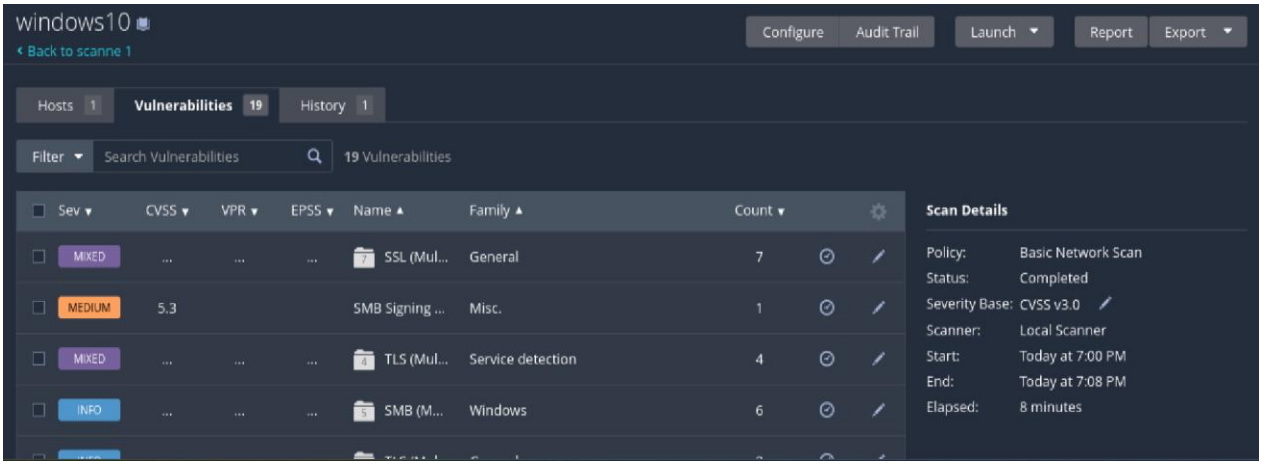
Un nouveau scan a été configuré avec les paramètres suivants :

- **Modèle :** Basic Network Scan (Standard industrie)



- **Cibles :** 192.168.56.20





- **Méthodologie :** Scan des ports, identification des services et comparaison avec la base de données de vulnérabilités.

3. Analyse des Résultats (Interprétation)

Chaque vulnérabilité détectée par Nessus est analysée selon les critères suivants :

D'après les résultats de votre scan Nessus sur la machine windows10

Voici les résultats du scan Nessus pour **windows10** :

Vulnérabilités trouvées :

1. SSL Multiple Issues

- Gravité : MIXED

- Famille : General

- Service : SSL/TLS

2. SMB Signing not required

- Gravité : MEDIUM (CVSS 5.3)

- Famille : Misc.

- Service : SMB (port 445)

3. TLS Multiple Issues

- Gravité : MIXED

- Famille : Service detection

- Service : TLS

4. SMB Multiple Issues

- Gravité : INFO

- Famille : Windows

- Service : SMB

5. TLS Multiple Issues

- Gravité : INFO
- Famille : General
- Service : TLS

6. DCE Services Enumeration

- Gravité : INFO
- Famille : Windows
- Service : RPC/DCOM (port 135)

7. Nessus SYN scanner

- Gravité : INFO
- Famille : Port scanners
- Service : Détection de ports

Résumé

- Scan terminé en 8 minutes
- Services vulnérables : SMB (445), TLS/SSL, RPC (135)

4. Recommandations de Hardening

Basé sur les résultats du scan, les actions suivantes sont préconisées pour "durcir" (Hardening) la posture de sécurité :

1. **Mise à jour des systèmes :** Appliquer les correctifs liés aux CVE critiques identifiées.
2. **Correction des configurations :** Désactiver les services inutiles identifiés lors du scan.

3. **Surveillance continue :** Planifier des scans réguliers pour détecter l'apparition de nouvelles vulnérabilités.
4. Ssh/tls multiple issues (MIXED)

   Désactiver les protocoles TLS/SSL vulnérables

   Via GPO ou registre :

   - Désactiver SSL 2.0, SSL 3.0, TLS 1.0, TLS 1.1

   - Garder uniquement TLS 1.2 et TLS 1.3

   Registre (Admin) :

   [HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\SCHANNEL\Protocols\TLS 1.0\Server]

   "Enabled"=dword:00000000

   "DisabledByDefault"=dword:00000001

   Redémarrer après modification